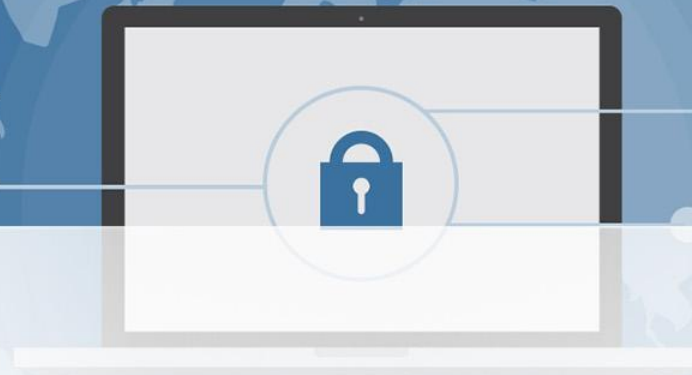




Information Security



COMPUTER



Systems, Devices,
Servers, etc.

INFORMATION



Data/Message

security



Privacy and Protection

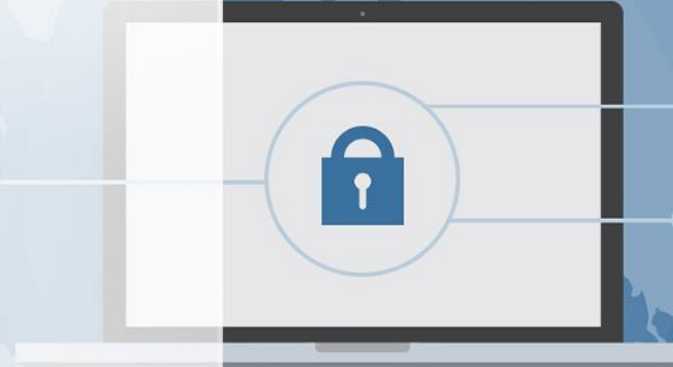
Computer Security

- Protection of Systems and Information.
 - From harm, theft and unauthorized use.
- Process of preventing and detecting unauthorized use of your information.
- There are various types of computer security which is widely used to protect the valuable information of an organization.



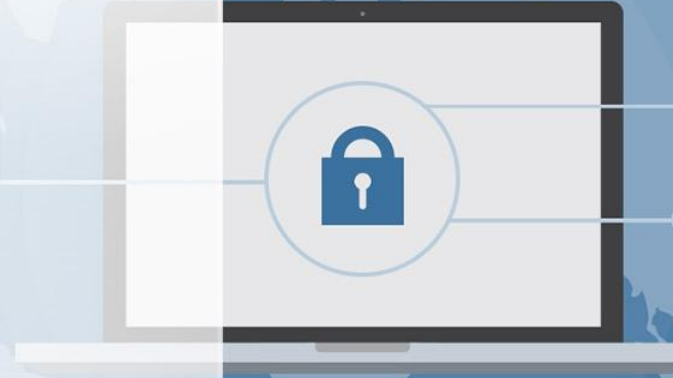
Information Security Assurance

- **Information security** is securing information from unauthorized access, modification & deletion
- **Application Security** is securing an application by building security features to prevent from Cyber Threats such as SQL injection, DoS attacks, data breaches and etc.
- **Computer Security** means securing a standalone machine by keeping it updated and patched



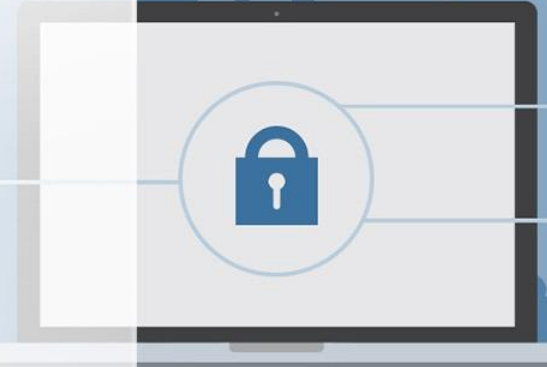
Contd.

- **Network Security** is by securing both the software and hardware technologies
- **Cybersecurity** is defined as protecting computer systems, which communicate over the computer networks.

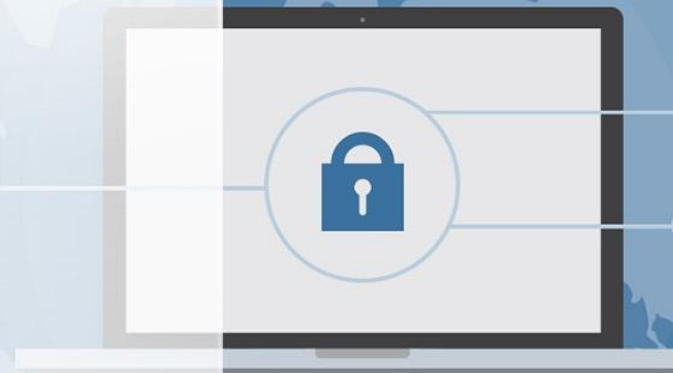


Components of ISA

- The components of a security system that needs to be protected are:
 - Hardware, the physical part of the computer, like the system memory and disk drive.
 - Firmware, permanent software that is etched into a hardware device's nonvolatile memory and is mostly invisible to the user.
 - Software, the programming that offers services, like operating system, word processor, internet browser to the user.



The CIA Triad



Rules

Confidentiality

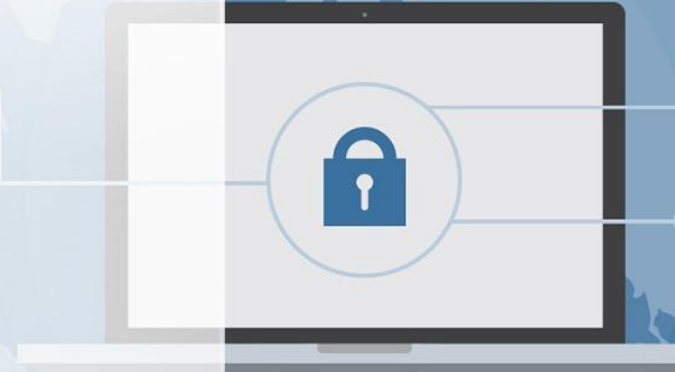
- "Keep secrets secret."

Integrity

- "Keep information correct and trustworthy."

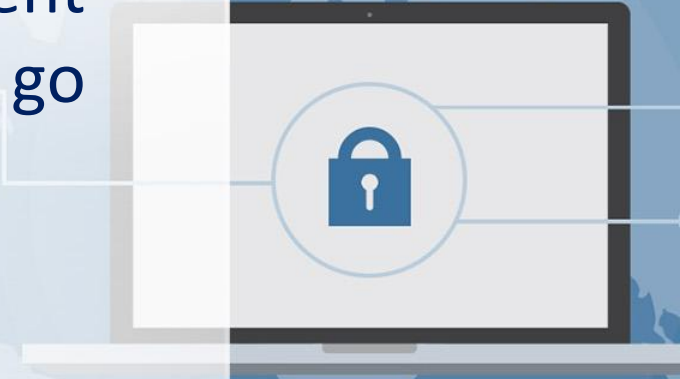
Availability

- "Keep systems usable when needed."



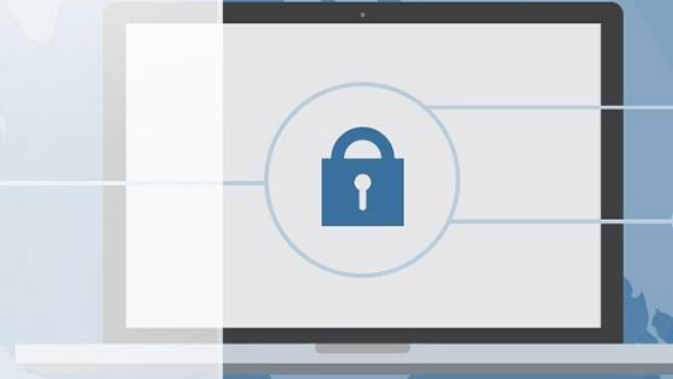
Question?

- Imagine your university's student database is hacked. What could go wrong?



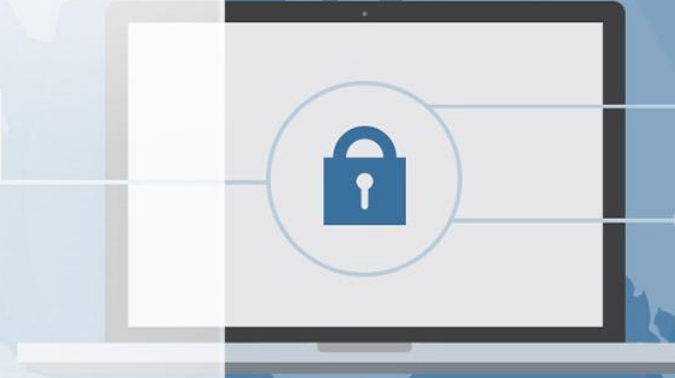
Question 1

- **Who should be allowed to see the information?**
- **→ Confidentiality**



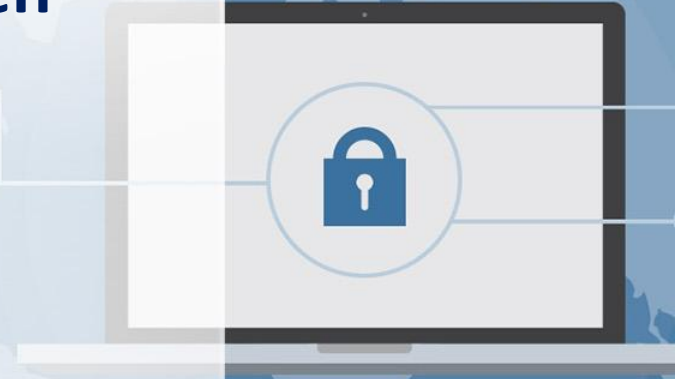
Question 2

- How do we know the information has not been changed?
- → Integrity



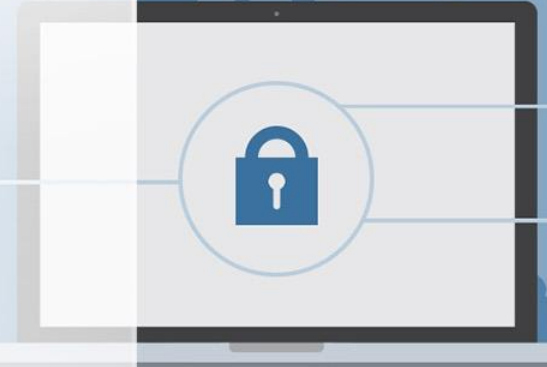
Question 3

- Can authorized users access it when they need it?
- → Availability



Information Security

- It is not simply about preventing hackers. It is about protecting information and systems from unauthorized disclosure, unauthorized modification, and disruption.

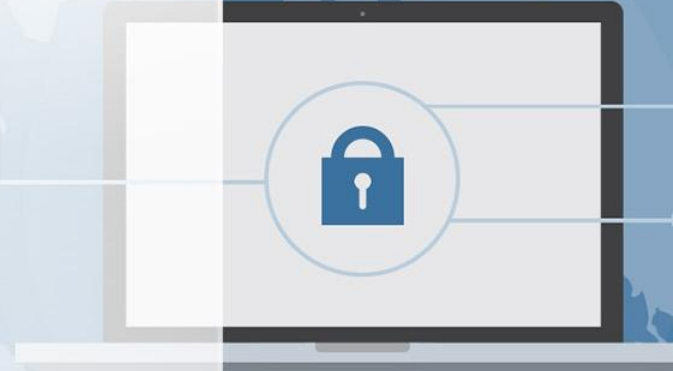


Confidentiality

Information is accessible only to authorized people, systems, or processes.

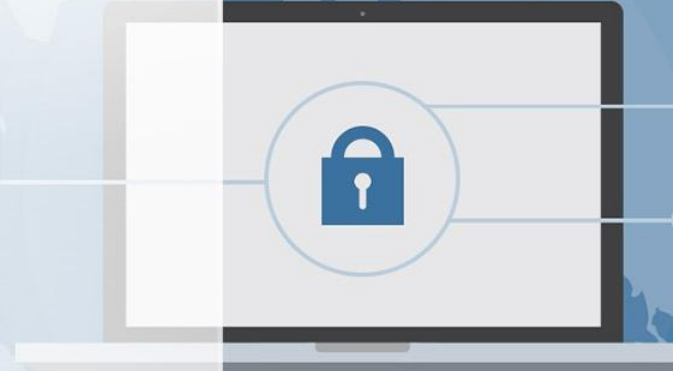
Examples

- Student grades
- Passwords
- Bank account information
- Medical records
- Military information
- Company trade secrets
- Private messages



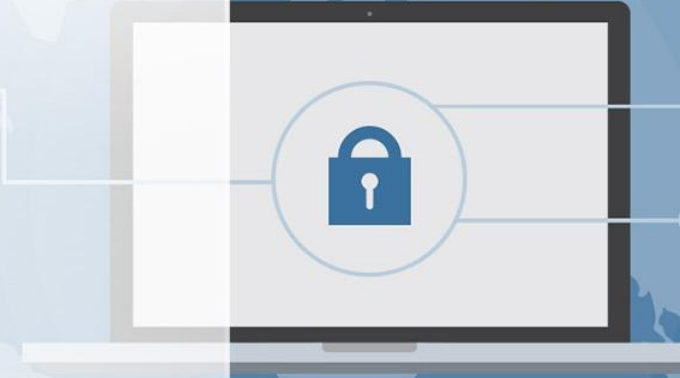
Common Threats

- Password theft
- Phishing
- Eavesdropping
- Sniffing
- Shoulder surfing
- Data breaches
- Malware
- Insider threats
- Misconfigured cloud storage



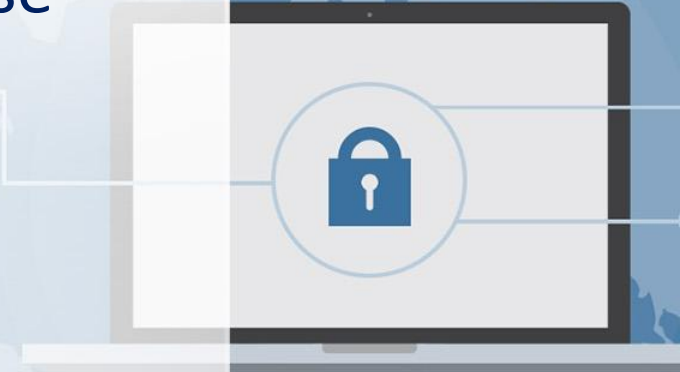
Suppose a university database contains:

- Student ID
- Name
- CNIC
- Phone Number
- Email
- Grades



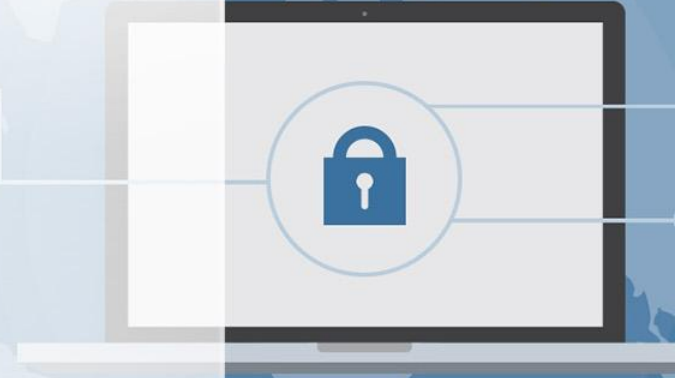
Question

- An attacker downloads the database but **doesn't modify anything**.
- Which CIA property is primarily violated and why?



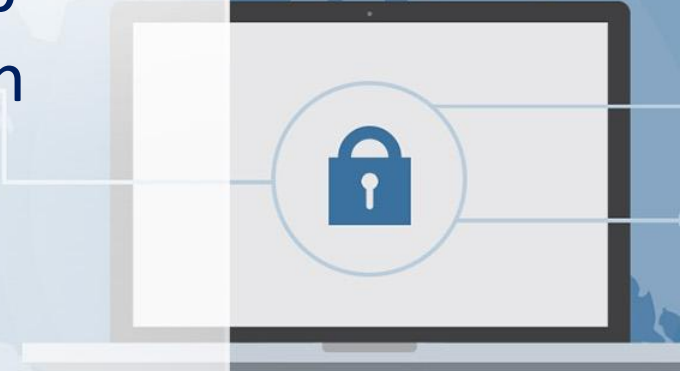
Answer

- **Confidentiality** because unauthorized people obtained information.



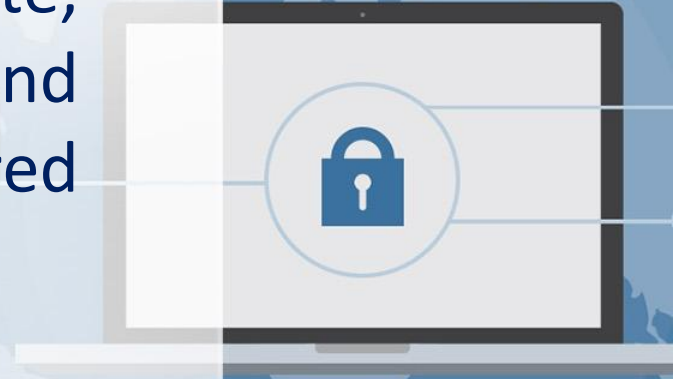
Questions

- If an attacker reads your WhatsApp message without changing it, which CIA property is violated?
- What if the attacker reads it AND changes the message?



Integrity

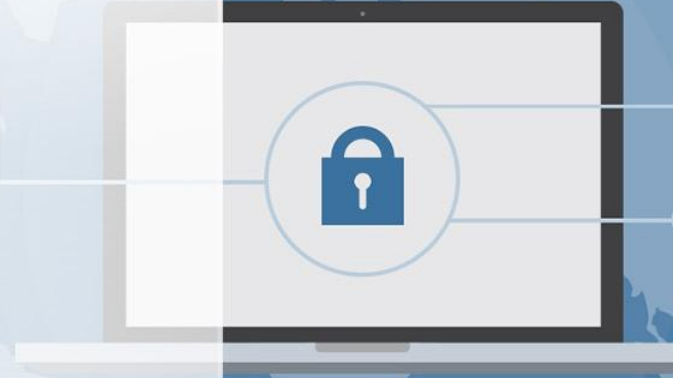
- Information remains accurate, complete, consistent, and trustworthy and is not altered without authorization.



Integrity is not only about hackers.

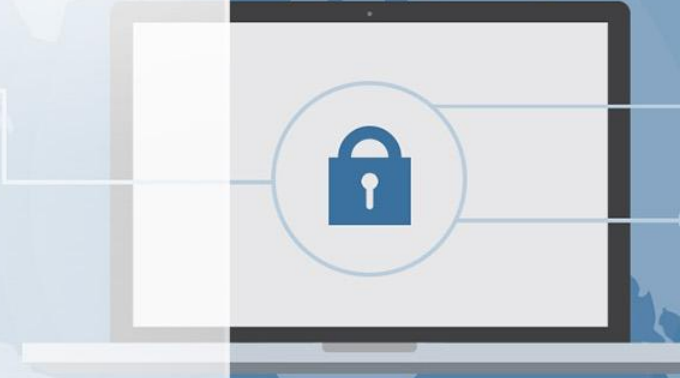
Information can lose integrity because of:

- Human error
- Software bugs
- Hardware failure
- Malware
- Unauthorized access
- Incorrect database operations
- Transmission errors



Integrity

- Integrity = correctness + trustworthiness + protection from unauthorized modification

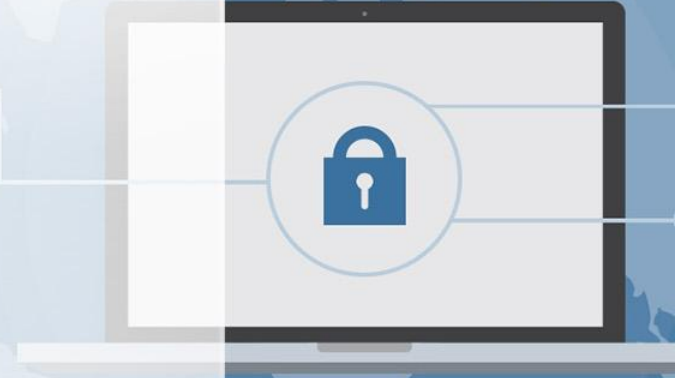


Availability

- Authorized users can access information, systems, and services when required.

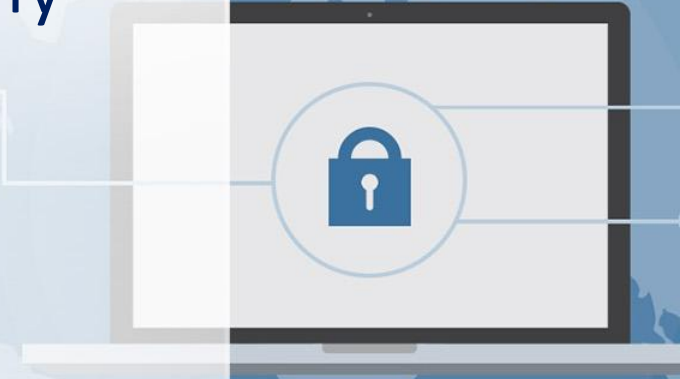
Examples

- Banking system
- University LMS
- Hospital emergency system
- DNS
- Cloud services
- Email
- Online examination system



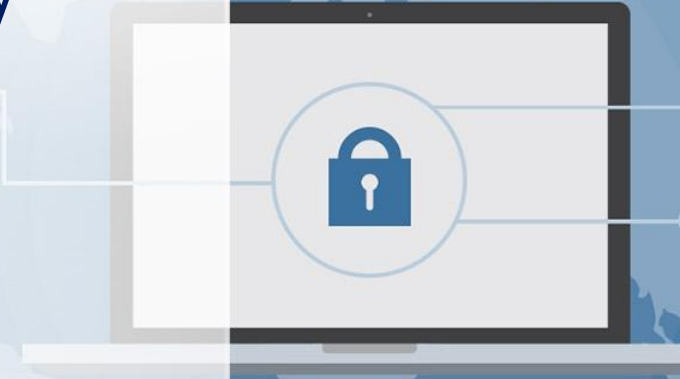
Availability attack scenario

- The attacker may not steal or modify any data. They simply prevent legitimate users from using the service.



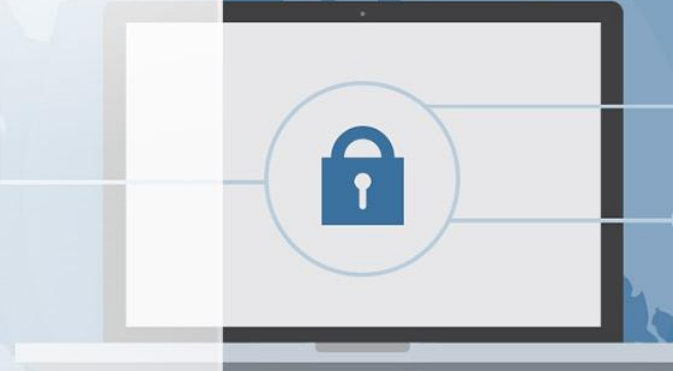
Availability Is More Than "Server Is On"

- Is a system available if it technically works but takes 30 minutes to respond?



Availability depends on:

- Uptime
- Performance
- Reliability
- Accessibility
- Recovery capability
- For a real-time system, **timely access** can be as important as simple uptime.



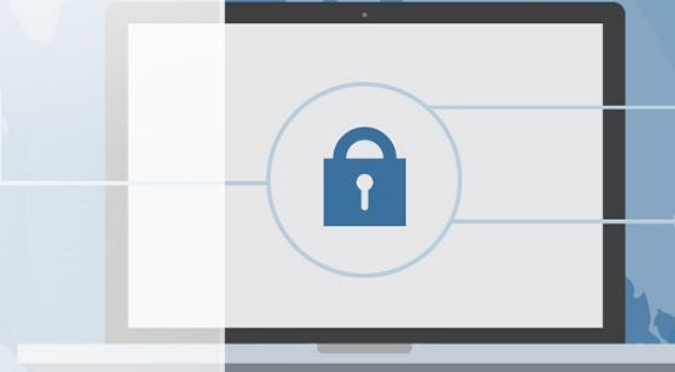
A cyberattack does not necessarily belong to only one CIA category.

Consider:

- **Ransomware**
- Attacker encrypts company files.
- Users cannot access them.
- → **Availability**
- But what if the attacker also steals the files before encryption?
- → **Confidentiality + Availability**
- What if the attacker modifies or corrupts files?
- → **Integrity + Availability**

Therefore:

- **One incident can affect all three.**

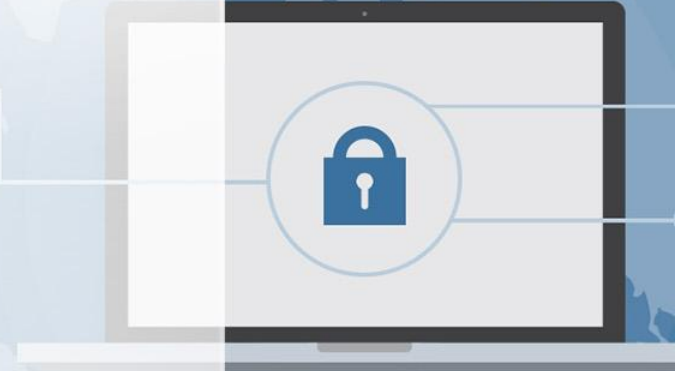


Scenario - University Examination System

A university conducts online examinations. On examination day, attackers compromise an administrator account.

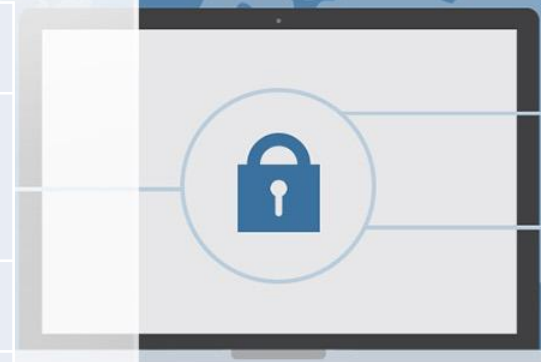
They:

- Download student records.
- Change examination marks.
- Delete some examination files.
- Make the LMS unavailable for two hours.



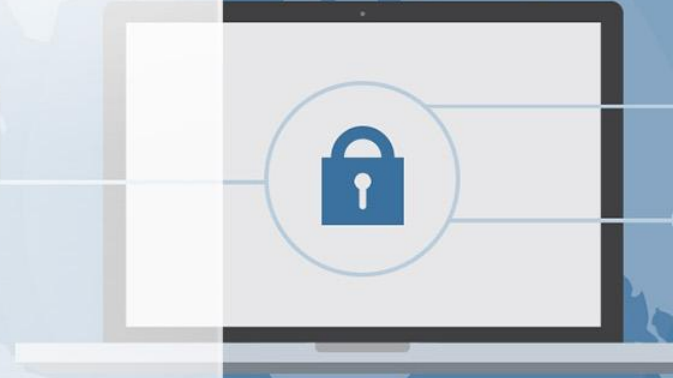
Student Task

Action	CIA Impact
Download student records	?
Change marks	?
Delete files	?
LMS unavailable	?



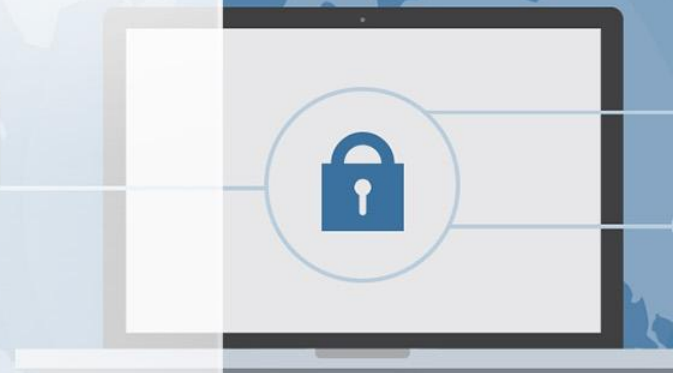
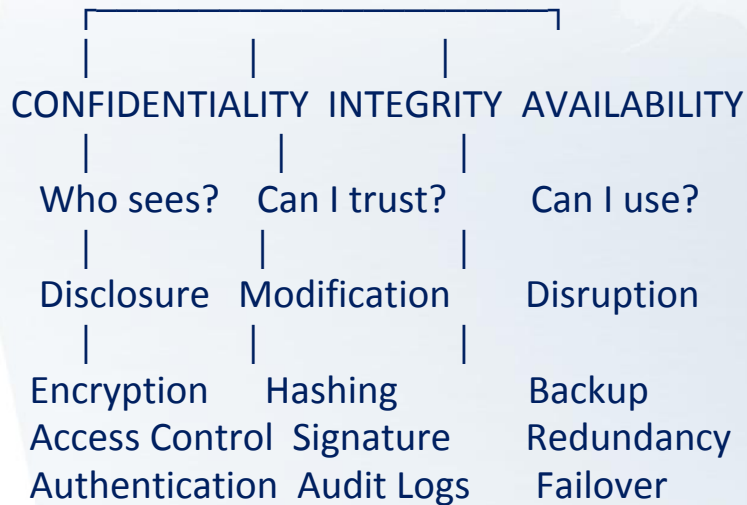
Security Controls for CIA

- Now move from:
- **"What went wrong?"**
- to:
- **"How do we prevent it?"**



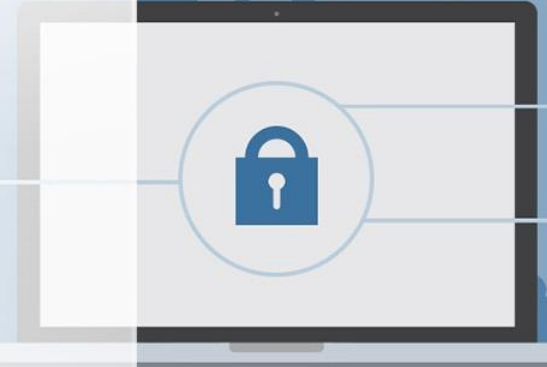
Information Security MAP

INFORMATION SECURITY



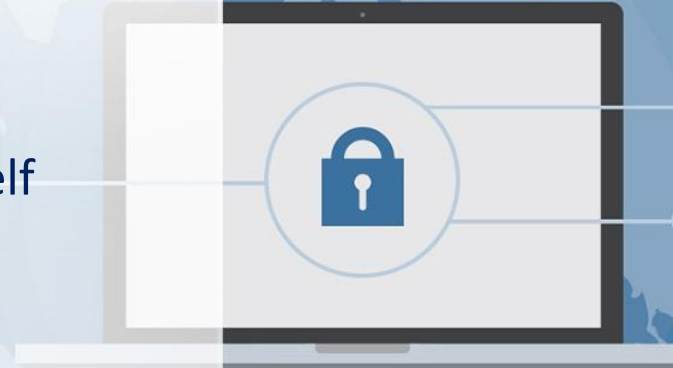
Different Terminologies

- Users: People authorized to use information technology (IT) resources.
- Administrator: See System Administrator.
- Threat: An action or event that poses a possible danger to a computer system. The potential for exploitation of a vulnerability.
- Firewall: A network device used to block network access to Information Technology resources.
- Software Patches: A piece of software designed to fix problems with, or update a computer program or its supporting data.



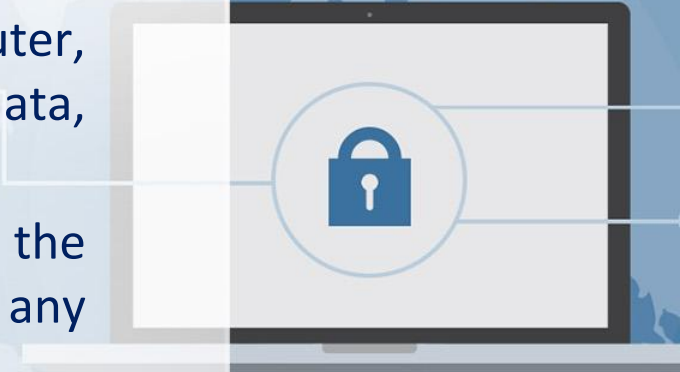
Contd.

- Spam Messages: The use of electronic messaging systems (e.g., email) to send unsolicited bulk messages indiscriminately.
- Virus: Malware that uses its host to propagate itself to other hosts.
- Third Party: not the original creator of a product.
- Server: A computer that makes services such as access to data files, programs, and peripheral devices, available to workstations on a network.



Contd.

- Unauthorized Access: When an external agent tries to take legitimate access to any system, computer, network, server, website, server-room, sensitive data, or someone else's account.
- Vulnerability: The vulnerability can be defined as the flaw or weakness in the design or development of any system.
- Hacker: Is a Person who tries and exploits a computer system for a reason which can be money, a social cause, fun etc.



Contd.

- **Attack:** Is an assault on the system security that is delivered by a person or a machine to a system. It violates security.
- **Antivirus or Antimalware:** Is a software that operates on different OS which is used to prevent from malicious software.



Student Task

- After DOS and DDOS attack in the main server of DUET, how will you safeguard your system.
- Suggest all the steps.

